

Vendor ID	Vendor Name	Service Provided	Data Types Processed	Risk Tier	Business Owner	Technical Owner	VSAQ Status	Last Assessment Date	POPIA Agreement Executed	Overall Status
VEN-001	PathLab SA (Pty) Ltd	Pathology API Integration	Patient ID, Blood Test & Diagnostic Data	Tier 1 (Critical)	Clinical Lead	IT Manager	Completed (68%)	2026-03-10	Pending Signature	Conditional Approval
VEN-002	CloudMed Systems	SaaS Patient Health Record System	Medical History, Prescriptions, Billing	Tier 1 (Critical)	CEO	IT Manager	Completed (92%)	2026-01-15	YES	Approved
VEN-003	PharmaLink SA	Digital e-Prescription Network	Patient Names, IDs, Medication Prescribed	Tier 2 (High)	Clinical Lead	IT Manager	Under Review	2026-02-20	YES	Approved
VEN-004	NetCare Telecoms	Fibre Infrastructure & Internet	Network Traffic (Encrypted Transit)	Tier 2 (High)	IT Manager	IT Manager	Completed (84%)	2025-11-10	YES	Approved
VEN-005	WasteCare SA	Hazardous & Paper File Destruction	Shredded Physical Patient Documents	Tier 2 (High)	Facilities Manager	Admin	Completed (88%)	2025-10-05	YES	Approved

Q ID	Security Domain	Question	ISO 27001 Ref	POPIA Ref	Response (Yes/Partial/No)	Points Offered (4 Max)	Vendor Evidence / Notes	Score
Q01	Governance	Does the vendor maintain a documented Information Security Policy?	A.5.1	Sec 19	Yes	4	Provided Information Security Policy v3.2	4
Q02	Governance	Has the vendor achieved ISO 27001 certification or independent audit?	A.5.35	Sec 19	Partial	2	ISO 27001 implementation in progress (no cert)	2
Q03	Governance	Does the vendor appoint a designated Information Officer?	A.5.2	Sec 55	Yes	4	Appointed IO registered with Information Regulator	4
Q04	Governance	Does the vendor conduct annual background checks on staff?	A.6.1	Sec 19	Yes	4	HR policy confirms criminal and credit checks	4
Q05	Governance	Does the vendor conduct annual security awareness training?	A.6.3	Sec 19(2)	Partial	2	Training provided at onboarding only	2
Q06	Access Control	Is Multi-Factor Authentication (MFA) enforced on all admin portals?	A.8.5	Sec 19	No	0	Password only; MFA planned for Q3	0
Q07	Access Control	Is Role-Based Access Control (RBAC) implemented based on least privilege?	A.8.2	Sec 19	Yes	4	RBAC configured in Active Directory	4
Q08	Access Control	Are user access rights reviewed at least quarterly?	A.8.2	Sec 19	No	0	Access reviews conducted annually	0
Q09	Access Control	Are administrative sessions automatically terminated after inactivity?	A.8.11	Sec 19	Yes	4	15-minute session timeout configured	4
Q10	Access Control	Is remote administrative access restricted via secure VPN?	A.8.20	Sec 19	Partial	2	VPN required but no device compliance checks	2
Q11	Encryption	Is patient data encrypted at rest using AES-256 or equivalent?	A.8.24	Sec 19	Yes	4	Databases encrypted using AWS KMS AES-256	4
Q12	Encryption	Is data in transit encrypted using TLS 1.2 or TLS 1.3?	A.8.24	Sec 19	Yes	4	TLS 1.3 enforced on API endpoints	4
Q13	Encryption	Are cryptographic keys managed separately from database storage?	A.8.24	Sec 19	Yes	4	AWS KMS key separation verified	4
Q14	Encryption	Are laptop hard drives protected with full-disk encryption?	A.7.9	Sec 19	Yes	4	BitLocker enforced on all staff endpoints	4
Q15	Encryption	Are database backups encrypted before off-site storage?	A.8.13	Sec 19	Partial	2	Backups encrypted, but keys stored on same server	2
Q16	Incident Response	Does the vendor maintain a documented Incident Response Plan?	A.5.24	Sec 22	Yes	4	IR Plan v2.1 provided	4
Q17	Incident Response	Does the vendor contractually commit to 24-hour breach notification?	A.5.26	Sec 22	No	0	Current policy specifies 5-day notification	0
Q18	Incident Response	Does the vendor conduct annual tabletop incident response exercises?	A.5.28	Sec 19	No	0	No tabletop simulations documented	0

Q ID	Security Domain	Question	ISO 27001 Ref	POPIA Ref	Response (Yes/Partial/No)	Points Offered (4 Max)	Vendor Evidence / Notes	Score
Q19	Incident Response	Are security event logs retained for at least 12 months?	A.8.15	Sec 19	Yes	4	Log retention set to 365 days in CloudWatch	4
Q20	Incident Response	Does the vendor maintain business continuity and DR plans?	A.5.30	Sec 19	Partial	2	DR plan exists, but recovery testing overdue	2
Q21	POPIA Obligations	Does the vendor agree to sign MediCare Connect's POPIA Operator Agreement?	A.5.20	Sec 21	Partial	2	Under legal review by vendor team	2
Q22	POPIA Obligations	Does the vendor store or process SA patient data outside South Africa?	A.5.14	Sec 72	No	4	All data hosted locally in AWS Cape Town region	4
Q23	POPIA Obligations	Does the vendor restrict sub-contractor processing without prior consent?	A.5.21	Sec 21	Yes	4	Sub-processors listed and contractually bound	4
Q24	POPIA Obligations	Does the vendor have a formal data sanitization policy upon contract termination?	A.7.14	Sec 14	Partial	2	Wiping promised, but no Certificate of Destruction	2
Q25	POPIA Obligations	Has the vendor received any enforcement notices from the Information Regulator?	A.5.31	Sec 55	Yes	4	No history of regulatory enforcement	4

Domain ID	Security Domain	Domain Weight	Total Questions	Max Points	Points Earned	Domain Score (%)	Risk Rating	Status
DOM-01	Governance & Compliance	20%	5	20	14	70.00%	Acceptable	Approved
DOM-02	Access Control & Authentication	20%	5	20	10	50.00%	High Risk	Needs Remediation (MFA Required)
DOM-03	Data Protection & Encryption	25%	5	20	18	90.00%	Low Risk	Approved
DOM-04	Incident Response & Continuity	20%	5	20	10	50.00%	High Risk	Needs Remediation (24h Notification)
DOM-05	POPIA Operator Obligations	15%	5	20	16	80.00%	Acceptable	Pending Agreement Execution
OVERALL	PathLab SA (Pty) Ltd Evaluation	100%	25	100	68	68.00%	MEDIUM RISK	PROVISIONAL CONDITIONAL APPROVAL